12.4.3 Revocation and signal updates

Revocation mechanisms help shorten the window of exposure between an event and its reflection in policy decisions. Tokens can be invalidated via revocation lists or introspection endpoints. Dynamic signals—such as device posture or risk level—can be pushed to the PDP or PIP through message queues or publish/subscribe systems, updating cached context proactively.

The goal is to propagate change, not just wait for expiration. The faster an authorization system reacts to new information, the more trustworthy its decisions.

12.4.4 ACME's approach to freshness

ACME's different platforms clearly illustrate these tradeoffs.

- Customers on the Customer Collaboration platform authenticate through ACME's customer information system, which issues OAuth tokens that are valid for one hour. Each token contains stable claims—such as customer ID and role—while dynamic data, like account status or fraud score, is retrieved from the customer database at login and refreshed every few hours. This approach balances performance and reliability for daily collaboration.
- Employees on the Customer Collaboration platform authenticate through ACME's internal identity service rather than OAuth. The PDP enriches their authentication context with HR and Finance data collected via internal APIs. Device posture, however, is transmitted as a signed token issued by the posture client on the employee's laptop. This short-lived token asserts that the device is compliant and up to date. It expires after fifteen minutes and must be reissued by the client, ensuring that device trust remains fresh even while HR and Finance data—cached daily—change far less often. This blend provides timely assurance on device security without overloading corporate systems.
- Engineers using deployment tools face stricter checks. The engineering environment requires the freshest signals. Employee identity and device status are verified at login, while on-call status is checked in real time